INFORME DE INCIDENTE DE CIBERSEGURIDAD

Análisis Forense, Remediación y Detección de Vulnerabilidades

Manuel Rosario Marín Fernández

19/03/2026

1. Resumen

El presente informe documenta el análisis forense, la identificación de vulnerabilidades y las acciones de remediación llevadas a cabo sobre un servidor de 4Geeks Academy que fue comprometido por un actor malicioso.

El 8 de octubre de 2024 a las 17:40:59 EDT, un atacante accedió al servidor como usuario root mediante SSH desde la dirección IP 192.168.0.134, obteniendo control total del sistema.

El servidor comprometido alojaba una instalación de WordPress con stack LAMP (Linux, Apache, MariaDB, PHP) y tenía expuestos los servicios SSH, FTP y HTTP. El análisis identificó cuatro vulnerabilidades críticas en la Fase 1 y una vulnerabilidad adicional en la Fase 2, todas las cuales han sido remediadas.

2. Información del Entorno

2.1 Infraestructura analizada

Componente	Detalle
Sistema operativo	Debian GNU/Linux 12 (Bookworm)
Kernel	6.1.0-25-amd64
IP del servidor comprometido	192.168.1.112
IP del atacante detectado	192.168.0.134
IP del analizador (Kali Linux)	192.168.1.11
Servidor web	Apache 2.4.62
Base de datos	MariaDB 10.11.6
Aplicación web	WordPress (stack LAMP)
Servidor FTP	vsftpd 3.0.3
Servidor SSH	OpenSSH 9.2p1

2.2 Herramientas utilizadas

Herramienta	Versión	Uso
Nmap	7.95	Escaneo de puertos y detección de vulnerabilidades
Nikto	2.5.0	Análisis de vulnerabilidades web
journalctl	systemd	Análisis de logs del sistema
Script bash personalizado	1.0	Recolección automatizada de evidencias forenses

3. Fase 1 - Análisis Forense y Corrección del Incidente

3.1 Metodología de análisis

Se ejecutó un script de análisis forense automatizado sobre la máquina comprometida que recopiló información de: usuarios del sistema, historial de login, procesos en ejecución, servicios activos, crontabs, archivos con permisos SUID, historial de comandos bash y logs del sistema.

3.2 Línea de tiempo del incidente

Fecha y hora	Evento
Jul 31, 2024	Primera instalación del sistema. Arranque inicial registrado.
Sep 30, 2024	Instalación del stack LAMP: Apache, MariaDB, PHP, WordPress y SSH.
Oct 8, 2024 - 17:28:38	Servicio SSH escuchando en 0.0.0.0:22 (expuesto a la red).
Oct 8, 2024 - 17:40:59	INTRUSIÓN: Acceso SSH aceptado para root desde 192.168.0.134.
Oct 8, 2024 - 17:40:59	Sesión de root abierta. El atacante tiene control total del sistema.
Oct 8 - después	auth.log y syslog eliminados. Borrado de huellas post-intrusión.
Mar 18, 2026	Inicio del análisis forense. Evidencias recopiladas.
Mar 19, 2026	Remediaciones aplicadas. Sistema asegurado.

3.3 Vulnerabilidades identificadas

Vulnerabilidad 1 - SSH con login root habilitado (CRÍTICA)

Campo	Detalle
Descripción	El servicio SSH permitía autenticación directa como usuario root con contraseña.
Severidad	CRÍTICA
Evidencia	journalctl: 'Accepted password for root from 192.168.0.134 port 45623 ssh2'
Archivo afectado	/etc/ssh/sshd_config - PermitRootLogin yes
Impacto	Acceso total al sistema como superusuario desde red externa.

Vulnerabilidad 2 - Contraseña débil en base de datos (CRÍTICA)

Campo	Detalle
Descripción	La base de datos WordPress usaba la contraseña '123456', la más común del mundo.

Campo	Detalle
Severidad	CRÍTICA
Evidencia	wp-config.php: define('DB_PASSWORD', '123456')
Archivo afectado	/var/www/html/wp-config.php
Impacto	Acceso total a la base de datos con datos de usuarios y contenido.

Vulnerabilidad 3 - FTP anónimo con escritura habilitada (ALTA)

Campo	Detalle
Descripción	vsftpd permitía conexiones anónimas sin contraseña con permisos de escritura y sin cifrado SSL.
Severidad	ALTA
Evidencia	vsftpd.conf: anonymous_enable=YES, write_enable=YES, ssl_enable=NO
Archivo afectado	/etc/vsftpd.conf
Impacto	Cualquier usuario podía conectarse y subir archivos arbitrarios (ej. webshells).

Vulnerabilidad 4 - Archivo info.php expuesto (MEDIA)

Campo	Detalle
Descripción	Se creó el archivo info.php con phpinfo() en el directorio web público.
Severidad	MEDIA
Evidencia	Historial bash: 'sudo nano /var/www/html/info.php'
Archivo afectado	/var/www/html/info.php
Impacto	Exposición de configuración interna del servidor PHP a cualquier visitante.

Eliminación de logs

Los archivos /var/log/auth.log y /var/log/syslog no existen en el sistema. Esto es una señal de borrado deliberado de evidencias por parte del atacante post-intrusión. La evidencia del acceso SSH se recuperó a través del journal de systemd.

3.4 Remediaciones aplicadas - Fase 1

#	Vulnerabilidad	Acción	Resultado
1	SSH root login	PermitRootLogin no / PasswordAuthentication no en sshd_config	Aplicado
2	Contraseña BD débil	Contraseña cambiada a cadena robusta de 20+ caracteres con símbolos	Aplicado

#	Vulnerabilidad	Acción	Resultado
3	FTP anónimo	anonymous_enable=NO, write_enable=NO, ssl_enable=YES	Aplicado
4	info.php expuesto	Archivo eliminado con rm -f	Aplicado
5	wp-config.php permisos	chmod 640, propietario www-data:www-data	Aplicado
6	IP atacante bloqueada	iptables -A INPUT -s 192.168.0.134 -j DROP + netfilter-persistent save	Aplicado

3.5 Verificación de remediaciones

Las siguientes verificaciones confirmaron la correcta aplicación de cada remediación:

```
grep PermitRootLogin /etc/ssh/sshd_config  →  PermitRootLogin no
grep PasswordAuthentication /etc/ssh/sshd_config  →  PasswordAuthentication no
grep anonymous_enable /etc/vsftpd.conf  →  anonymous_enable=NO
grep ssl_enable /etc/vsftpd.conf  →  ssl_enable=YES
ls /var/www/html/info.php  →  No such file or directory (eliminado)
ls -la /var/www/html/wp-config.php  →  -rw-r----- 1 www-data www-data (640)
sudo iptables -L INPUT -n -v | grep 192.168.0.134  →  DROP (regla activa)
cat /etc/iptables/rules.v4 | grep 192.168.0.134  →  -A INPUT -s 192.168.0.134/32
-j DROP
```

4. Fase 2 - Detección y Corrección de Nueva Vulnerabilidad

4.1 Metodología de escaneo

Desde la máquina Kali Linux (192.168.1.11) se realizaron tres escaneos independientes sobre el servidor comprometido (192.168.1.112):

- Nmap con detección de versiones y scripts: nmap -sV -sC -A -p-
- Nmap con scripts de vulnerabilidades: nmap --script vuln
- Nikto para análisis de vulnerabilidades web: nikto -h http://192.168.1.112

4.2 Resultados del escaneo

Puertos y servicios detectados

Puerto	Servicio	Versión	Estado
21/tcp	FTP	vsftpd 3.0.3	Abierto
22/tcp	SSH	OpenSSH 9.2p1 Debian	Abierto
80/tcp	HTTP	Apache httpd 2.4.62 (Debian)	Abierto

Hallazgos de Nikto

Hallazgo	Descripción	Severidad
xmlrpc.php expuesto	Endpoint de WordPress accesible públicamente. Vector de ataques de fuerza bruta y amplificación.	ALTA
Sin X-Frame-Options	Header de seguridad ausente. Permite ataques de clickjacking.	MEDIA
Sin X-Content-Type-Options	Header ausente. Permite MIME sniffing.	BAJA
Directory listing en /wp-content/uploads/	Listado de archivos accesible públicamente. Exposición de información.	MEDIA
ETag con inode (CVE-2003-1418)	El servidor puede filtrar información del inode del sistema de archivos.	BAJA

4.3 Vulnerabilidad seleccionada para Fase 2

xmlrpc.php expuesto en WordPress - Vector de ataque confirmado

Campo	Detalle
Descripción	El archivo xmlrpc.php de WordPress estaba accesible públicamente sin restricción.
Herramienta de detección	Nikto 2.5.0
Severidad	ALTA

Campo	Detalle
Evidencia	Nikto: '/xmlrpc.php was found.' - HTTP 200 desde IP externa
Diferencia con Fase 1	Fase 1: vulnerabilidades de configuración de servicios. Fase 2: exposición de endpoint de aplicación web.
Vectores de ataque posibles	Fuerza bruta de credenciales, ataques de amplificación DDoS, explotación de métodos XML-RPC.
CVE relacionado	Sin CVE único - problema conocido en seguridad WordPress (OWASP Top 10: A05 Security Misconfiguration)

4.4 Remediación aplicada - Fase 2

Bloqueo de xmlrpc.php mediante .htaccess

Se añadió la siguiente directiva al archivo /var/www/html/.htaccess para bloquear el acceso al endpoint desde cualquier origen:

```
# Bloquear xmlrpc.php - Vector de ataque WordPress
<Files xmlrpc.php>
    Order Deny,Allow
    Deny from all
</Files>
```

Verificación de la remediación

Se verificó desde la máquina Kali Linux mediante el siguiente comando:

```
curl -s -o /dev/null -w "%{http_code}" http://192.168.1.112/xmlrpc.php
Resultado: 403 Forbidden   (antes: 200 OK)
```

5. Resumen Global de Vulnerabilidades y Remediaciones

#	Vulnerabilidad	Fase	Severidad	Estado
1	SSH - login root habilitado con contraseña	1	CRÍTICA	Remediado
2	WordPress - contraseña de BD trivial (123456)	1	CRÍTICA	Remediado
3	FTP anónimo con escritura y sin SSL	1	ALTA	Remediado
4	info.php con phpinfo() expuesto	1	MEDIA	Remediado
5	xmlrpc.php accesible públicamente	2	ALTA	Remediado
6	IP atacante 192.168.0.134 sin bloquear	1	ALTA	Remediado
7	Directory listing /wp-content/uploads/	2	ALTA	Remediado

#	Vulnerabilidad	Fase	Severidad	Estado
8	Headers HTTP ausentes (X-Frame, X-Content)	2	MEDIA	Remediado
9	ETag con informacion de inode (CVE-2003-1418)	2	MEDIA	Remediado
10	robots.txt revela rutas administrativas	2	BAJA	Remediado

6. Recomendaciones Adicionales

Las siguientes medidas se recomiendan para fortalecer aún más la seguridad del servidor:

- Implementar autenticación por clave pública SSH y eliminar completamente la autenticación por contraseña.
- Mantener una lista negra de IPs atacantes conocidas actualizada en iptables/UFW. La IP 192.168.0.134 ya ha sido bloqueada con iptables -A INPUT -s 192.168.0.134 -j DROP y persistida con *netfilter-persistent*.
- Configurar un firewall (UFW/iptables) para limitar el acceso a los puertos 22, 21 y 80 solo a IPs autorizadas.
- Evaluar si el servicio FTP es necesario. Si no lo es, deshabilitarlo completamente con: systemctl disable vsftpd.
- Habilitar el logging persistente de auth.log configurando rsyslog o syslog-ng para evitar la pérdida de evidencias.
- Instalar y configurar Fail2Ban para bloquear automáticamente IPs con múltiples intentos de autenticación fallidos.
- Mantener WordPress y todos sus plugins actualizados. Usar plugins de seguridad como Wordfence o iThemes Security.
- Añadir headers de seguridad HTTP en Apache: X-Frame-Options, X-Content-Type-Options, Content-Security-Policy.
- Deshabilitar el listado de directorios en Apache cambiando 'Options Indexes' a 'Options -Indexes'.
- Implementar copias de seguridad automáticas y almacenarlas en ubicación separada del servidor.
- Realizar análisis de vulnerabilidades periódicos (mensualmente) con las herramientas utilizadas en este proyecto.

7. Conclusiones

El análisis forense confirmó que el servidor fue comprometido el 8 de octubre de 2024 mediante acceso SSH directo como root desde la IP 192.168.0.134, aprovechando una combinación de configuración insegura (PermitRootLogin yes) y contraseñas débiles.

Se identificaron y remediaron diez vulnerabilidades en total: cuatro en la Fase 1 correspondientes a configuraciones inseguras de servicios críticos, y seis en la Fase 2 incluyendo exposición de endpoints WordPress, directory listing, headers HTTP ausentes, ETag con inode, robots.txt con rutas sensibles y la IP atacante sin bloquear. Todas han sido verificadas y confirmadas como efectivas.

Todas las remediaciones han sido verificadas y confirmadas como efectivas. El servidor se encuentra actualmente en un estado significativamente más seguro, aunque se recomienda implementar las medidas adicionales descritas en la sección anterior para alcanzar un nivel de seguridad óptimo

8. Anexos

Anexo A - Comandos de análisis forense ejecutados

```
cat /etc/passwd | grep ':0:'          # Usuarios con UID 0
last && lastlog                        # Historial de logins
ss -tulpn                              # Puertos y servicios
crontab -l && cat /etc/crontab         # Tareas programadas
find / -perm -4000 -type f 2>/dev/null # Archivos SUID
sudo journalctl _COMM=sshd | tail -100 # Logs SSH
cat /var/log/apache2/access.log        # Logs Apache
```

Anexo B - Comandos de escaneo Fase 2

```
sudo nmap -sV -sC -A -p- 192.168.1.112 -oN fase2_nmap_completo.txt
sudo nmap --script vuln 192.168.1.112 -oN fase2_nmap_vuln.txt
nikto -h http://192.168.1.112 -o fase2_nikto.txt
```

Anexo C - Verificación de remediaciones

```
# SSH
grep -v '^#' /etc/ssh/sshd_config | grep -v '^$'
# FTP
grep -E 'anonymous_enable|write_enable|ssl_enable' /etc/vsftpd.conf
# WordPress
ls -la /var/www/html/wp-config.php
# xmlrpc.php bloqueado
curl -s -o /dev/null -w "%{http_code}" http://192.168.1.112/xmlrpc.php
```

Anexo D - Bloqueo de IP atacante

```
curl -s -o /dev/null -w "%{http_code}" http://192.168.1.112/xmlrpc.php# Bloquear
IP atacante permanentemente
sudo iptables -A INPUT -s 192.168.0.134 -j DROP
sudo apt-get install iptables-persistent -y
sudo netfilter-persistent save
# Verificar regla activa
sudo iptables -L INPUT -n -v | grep 192.168.0.134
cat /etc/iptables/rules.v4 | grep 192.168.0.134
```